Training Register Demo - Data Protection Impact Assessment

SYN-TRN-DPIA-DOC01-001 | 1.0.0 | SYNTHETIC TEST FIXTURE

Repository: https://github.com/rdhepe/testrepo

S1 - Context and data subjects

Shared synthetic draft for UC3-WF-01, UC3-DOC-01 and the implemented privacy and security control test cases. SME approval is pending. No enterprise approval, legal basis or production compliance is asserted.

Training Register Demo (SYN-TRN-001) registers employees for training and tracks course completion. Data subjects are fictional employees enrolled as learners. All records and contacts are fabricated.

S2 - Personal-data categories and fields

Employee identification data: employeeId identifies an employee's enrolment; employeeName identifies the learner. Contact data: workEmail records the learner's work contact.

Learning data: courseCode identifies the training course; completionStatus tracks training progress linked to the employee. Both are personal information in an employee-linked enrolment, although neither identifies a person in isolation.

Record identification data: id is an application-generated UUID associated with an employee on newly created records only; seed records have no id.

The synthetic business contact ownerEmail (training.owner@example.test) belongs to application metadata, not learner enrolment records. No passwords, national IDs, IP addresses, authentication tokens, health data or financial data are stored in enrolment records.

S3 - Processing purposes

Purpose P1: register employees for training. employeeId and employeeName associate an enrolment with the learner; workEmail records the learner's work contact; courseCode selects the training course.

Purpose P2: track course completion. completionStatus records enrolled or completed progress against the employee and course. The generated id distinguishes newly created enrolment records.

The application does not send emails, perform marketing, profile employees, or make automated decisions. No consent workflow is implemented.

S4 - Collection, use and sharing

Collection: POST /api/enrolments accepts employeeId, employeeName, workEmail, courseCode and completionStatus from a local HTTP client. The application generates id; clients cannot submit additional fields.

Use: the Node.js service validates input, adds the enrolment to its in-memory array and returns the created record. GET /api/enrolments returns records to any local client without authentication.

Sharing: the local tester is the only intended API recipient, but access is not enforced by identity. No external service integration or email delivery is implemented. Publishing the repository exposes its synthetic seed data and documents according to GitHub repository visibility.

S5 - Storage and retention

Two synthetic seed enrolments persist in fixtures/application.json on the local machine. Runtime enrolments are stored only in Node.js process memory on that machine and are lost on restart; the seed file remains unchanged until manually removed.

No database, cloud deployment, backup, cross-border transfer or automated retention/deletion mechanism is implemented. The service binds to loopback (127.0.0.1) and uses cleartext HTTP. There is no authentication, authorization, audit trail or application encryption-at-rest mechanism. Use synthetic data only.

S6 - Open questions and incomplete statements

The country in which the local tester runs the machine is not specified. A fixed retention period for the seed file is not specified. The repository visibility is not specified in this DPIA.

A future export might be shared with a training partner. The partner, export fields, destination and timing are undecided. This is an ambiguous future proposal, not an implemented processing activity or an approved purpose.

S7 - Privacy statement requirement

Control TC-PD-03: A privacy statement shall be publicly available and easily accessible to users. The Training Register Demo homepage shall provide a clearly identifiable privacy statement link before users submit employee enrolment data. Users shall be able to open and read the statement without authentication or other access restrictions.

The statement shall describe the personal data collected, the training registration and completion-tracking purposes, intended recipients, storage and retention, and a privacy contact. This is a required control, not an assertion that the supplied frontend implements it. This DPIA is an assessment document, not a substitute for the user-facing statement.

The local registration homepage is served at GET / and submits the five declared client fields to POST /api/enrolments. Code review must compare the supplied homepage and its browser script against this requirement. Repository inspection alone cannot establish deployed accessibility or exclude a statement supplied outside this repository; live verification remains outstanding.

S8 - Consent requirement

Control TC-PD-02: Personal data shall be collected only with user consent. For this synthetic assessment scenario, user consent is required before employee enrolment information is submitted and stored. The registration frontend shall collect an affirmative consent choice before submission, and the application shall block storage when that consent is absent.

This requirement is a synthetic assessment assumption, not a determination that employee consent is an appropriate lawful basis in a real deployment. No actual legal basis, valid consent or employee approval is asserted. The requirement does not assert that the supplied application implements consent collection or enforcement.

Assess public/index.html and public/app.js for consent collection first. Consider backend findings in src/server.js only if no frontend findings exist. Use this DPIA to establish whether consent is required; database consent-record requirements are outside this assessment scope. Repository inspection cannot establish whether a person actually provided valid consent before every data write; that remains a manual verification.

S9 - Encryption-key storage and rotation requirement

Control TC-DS-03: The proposed enrolment encryption key shall be stored in a managed key service with access restricted to distinct key-administrator and application roles. Automatic key rotation shall be configured at least every 90 days.

This requirement applies to Resources.EnrolmentKey in infra/tc-ds-03-key.json, an undeployed AWS KMS configuration fixture. Its key policy restricts access to role parameters, but EnableKeyRotation and RotationPeriodInDays are deliberately absent. Permission to enable rotation does not configure rotation. The expected configuration verdict is Non-Compliant for missing automatic rotation; the 90-day interval is synthetic, not an enterprise-policy assertion.

The template is not connected to the running application and contains no key material or credentials. Existing seed JSON and runtime memory are not encrypted by it. Do not deploy the template or infer live key storage, effective permissions, actual rotation, or runtime data encryption from this configuration. Live verification and SME approval remain pending.

S10 - Identity-provider and MFA requirement

Control TC-DS-05: Training Register Demo is an internal employee application. Employee enrolment records are designated protected sensitive data for this synthetic control, not special-category personal data. Access to GET and POST /api/enrolments shall require authentication through Microsoft Entra with MFA before records can be read or created.

The supplied application deliberately permits anonymous reads and writes without identity-provider integration or token validation. The expected verdict is Non-Compliant because protected records are accessible without approved authentication. Loopback binding does not enforce identity. This requirement does not assert that the application implements authentication or MFA.

The worksheet assumption that MFA is enabled when an identity provider is used is an assessment shortcut, not evidence of effective MFA. No provider protects these routes. GitHub-only review can establish the absent application authentication gate but cannot perform login tests or determine live tenant policy. Do not report that a tenant's MFA is disabled without evidence.

S11 - Sensitive-data audit logging requirement

Control TC-DS-06: Reads through GET /api/enrolments and creation through POST /api/enrolments shall produce audit events containing authenticated user identity, UTC timestamp, action, record reference and outcome. Enrolment records are designated protected sensitive data for this synthetic control, not special-category personal data.

Record the attempt before access or mutation and its outcome when known, linked by a correlation identifier. A list-read event shall reference the collection and returned records; a create event shall reference the generated id. Seed records have no id and require pseudonymous stable references. Audit events shall not contain full request or response payloads, learner names, email addresses, credentials or tokens.

The supplied application deliberately has no read/create audit events or audit sink. Its startup URL message is not an audit trail. The expected verdict is Non-Compliant for missing audit logging. This is a required control, not implemented logging. Authentication is absent as tracked separately by TC-DS-05; client-supplied identity is not verified identity. Only read and create are implemented, not update or delete.

Compare the handlers in src/server.js against this requirement using application code analysis. A generic log statement alone does not prove required metadata, operation coverage or recorded outcome. GitHub-only inspection cannot establish live log delivery, retention, tamper protection or logging supplied outside the repository. Actual UC3 execution and SME approval remain pending.